



File No.: EXP202302620

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: A.A.A. (hereinafter, the complainant) filed a complaint with the Spanish Agency for Data Protection on 01/02/2023. The complaint is directed against APOLLONIA TOPCO, S.L. with NIF B88526116 (hereinafter, the respondent or Dental Clinic Sagrada Familia de Barcelona or the Clinic). The reasons for the complaint are as follows:

The complainant states that the respondent requests a copy of their ID card as a requirement to reimburse an amount overpaid for a treatment received, rejecting the three possible alternatives proposed, which include the possibility of making the refund via transfer to the bank account that has already been communicated to the respondent, a guaranteed bank check in the name of the complainant, or cash, with the corresponding receipt signed.

It is noted that the AEPD has issued a report in response to an inquiry made by the complainant regarding this matter. The complainant believes that, according to the cited report, in this case, the principles of purpose limitation and data minimization are not met, violating Articles 5.1.b) and 5.1.c) of the GDPR. The necessity of having a photocopy of the ID card to achieve the intended purpose, the refund, is not justified.

On 24/12/2022, the complainant sent an email to the Clinic, addressed to its data protection officer, without receiving a response, thus denouncing the inactivity or ineffectiveness of the DPO of the medical center.

Along with the notification, a copy of the email sent to the DPO of the respondent and the response provided by the AEPD to the inquiry made by the complainant regarding the facts that motivate the complaint is attached.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter LOPDGDD), the complaint was forwarded to the respondent for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The forwarding was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

2/17

Public (hereinafter, LPACAP), was received on 02/03/2023 as evidenced by the acknowledgment of receipt in the file.

On 31/03/2023, this Agency received a written response from the party being claimed against, in which it states the following:

It confirms the receipt of the inquiry made by the claiming party to the DPD of the party being claimed against, specifying that it was sent via the clinic's email, which is managed by reception staff and is not the usual channel established for this purpose. It justifies the lack of response as an oversight by the person who received the communication and should have forwarded it to the DPD, as stated in the clinic's protocols.

It indicates that the inquiry has been addressed during the process of transferring the claim, having justified to the interested party the need to provide a copy of the ID card.

With its response, the party being claimed against provides a report on the processing and decisions made regarding the claim with the following content:

“Information on the processing

Administrative procedures, including the processing of refunds of the balance in favor of patients

and/or clients, are managed by the administration department located at the headquarters. Each clinic is responsible for collecting requests and forwarding them to that department.

In this regard, to avoid possible fraud and identity theft, it is important to highlight that the practice of collecting a copy of the ID card is carried out exclusively when requesting the extraction of the available balance, to fulfill the specific purpose of verifying the identity of the patient or client and processing their refund with due diligence. This protocol is the result of analyzing the associated risks, considering not only economic damages but also those arising from a possible loss of access to a healthcare service already paid for. In this way, the Data Protection Officer has assessed that this practice complies with the principles of minimization and limitation, as only the personal data necessary to fulfill the specific purpose of managing the refund is collected, making the collection of the ID card necessary, appropriate, and relevant to unequivocally verify the identification, ensure the security of the process, and guarantee that the refund is made to the correct person. Likewise, no equally effective and secure alternative measures have been found.

Logically, this copy of the document is kept for the minimum time necessary to carry out the purpose, maintaining it duly blocked to demonstrate compliance with due diligence against possible liability claims during the legally established timeframes.

Decision made regarding the claim

First of all, a response has been provided to the claiming party regarding the inquiry raised as of the date of submission of this document.

On the other hand, after conducting the necessary investigations, the cause of the omission of the communication could not be determined. However, a meeting has been convened with all the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/17

staff of the organization to emphasize the obligation and importance of forwarding all communications addressed to the Data Protection Officer to the designated email account, regardless of the channel chosen by the interested party. Furthermore, the Data Protection Officer will conduct recurring and random simulations in all clinics to verify compliance with the established protocol.” It also provides a copy of the response given to the complaining party regarding their complaint, with identical content to the previous report on the processing.

THIRD: On 04/27/2023, in accordance with Article 65 of the LOPDGDD, the complaint submitted by the complaining party was admitted for processing.

FOURTH: On 07/19/2023, the General Subdirectorate of Data Inspection accessed information related to the complained party available on the websites “omfocif.economia3.com” and “einforma.com”. (...)

FIFTH: On 07/21/2023, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the complained party, in accordance with the provisions of Articles 63 and 64 of the LPACAP, for the following alleged infringements:

- Infringement of Article 5.1.c) of the GDPR, classified under Article 83.5.a) of the same Regulation, and qualified as very serious for the purposes of prescription in Article 72.1.a) of the LOPDGDD.
- Infringement of Article 38 of the GDPR, classified under Article 83.4.a) of the same Regulation, and qualified as serious for the purposes of prescription in Article 73.w) of the LOPDGDD.

In the opening agreement, it was determined that the sanction that could correspond, given the existing evidence at the time of the opening and without prejudice to what results from the instruction, would amount to a total of 30,000 euros (thirty thousand euros): 20,000 euros (twenty thousand euros) for the alleged infringement of Article 5.1.c) of the GDPR, and 10,000 euros (ten thousand euros) for the alleged infringement of Article 38 of the GDPR. Furthermore, it was warned that the alleged infringements, if confirmed, could lead to the imposition of measures in accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR.

On the other hand, the complained party was informed that if they did not make allegations regarding

this initiation agreement within the stipulated period, it could be considered a proposal for resolution, as established in Article 64.2.f) of the LPACAP.

SIXTH: The notification of the opening agreement mentioned in the previous antecedent, which granted a period to formulate allegations and propose evidence, was delivered to the complained party through the Single Enabled Electronic Address (DEHU) on 07/21/2023.

SEVENTH: Once the aforementioned initiation agreement was notified in accordance with the established rules in the LPACAP and the period granted for the formulation of allegations had elapsed, it was confirmed that no allegations had been received from the complained party.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

4/17

Article 64.2.f) of the LPACAP -a provision of which the complained party was informed in the opening agreement of the procedure- establishes that if no allegations are made within the stipulated period regarding the content of the initiation agreement, when it contains a precise statement regarding the attributed responsibility, it may be considered a proposal for resolution. In this case, the initiation agreement of the sanctioning file determined the facts in which the accusation was specified, the infringements of the GDPR attributed to the complained party, and the sanctions that could be imposed. Therefore, considering that the complained party has not made allegations to the initiation agreement of the file and in accordance with the provisions of Article 64.2.f) of the LPACAP, the aforementioned initiation agreement is considered in this case as a proposal for resolution.

In view of all that has been done, the Spanish Agency for Data Protection considers the following facts proven in the present procedure,

PROVEN FACTS

FIRST: The complaining party is a client of the complained party, which provides medical services and operates several dental clinics.

This contractual relationship generated an obligation for the complained party to reimburse an amount to the complaining party. To effectuate the payment of these reimbursements, the complained party has required its clients to provide a copy of their identity document, and this was demanded from the complaining party.

SECOND: On 12/24/2022, the complaining party sent an email to the complained party, addressed to its data protection officer, regarding the requirement for a copy of their identity document to receive the reimbursement of the amount owed by the complained party.

This email was not forwarded by the complained party to its DPO, so the issues raised by the complaining party were not responded to by them.

THIRD: The complained party prepared a report on the facts mentioned in Proven Facts One and Two, which was submitted by them to the proceedings by means of a document dated 03/31/2023, presented to this Agency in connection with the processing of the complaint filed by the complaining party.

In this report, the following is stated:

“Information on the processing

Administrative procedures, including the processing of refunds of the balance in favor of patients and/or clients, are managed by the administration department...

In this regard, to avoid possible fraud and identity theft, it is important to highlight that the practice of collecting a copy of the ID card is carried out exclusively when...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

5/17

requests the extraction of the available balance, to fulfill the specific purpose of verifying the identity of

the patient or client and processing their reimbursement with due diligence...

Decision made regarding the claim...

On the other hand, after conducting the appropriate investigations, the cause of the omission of communication could not be determined. However, a meeting has been convened with all the personnel of the organization to emphasize the obligation and importance of forwarding all communications addressed to the Data Protection Officer to the designated email account for this purpose, regardless of the channel chosen by the interested party...

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR) and as established in Articles 47, 48.1, 64.2, and 68.1 of the LOPDGDD, the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Unfulfilled obligation. Excessive data processing

Article 5 of the GDPR refers to the principle of data minimization in paragraph 1, letter c) in the following terms:

"Article 5 Principles relating to processing

1. Personal data shall be:

c) adequate, relevant, and limited to what is necessary in relation to the purposes for which they are processed ('data minimization')."

The entity being claimed against is a company that provides medical services and operates several dental clinics, including the Sagrada Familia Dental Clinic in Barcelona, of which the claimant is a client.

For reasons unknown, the services received by the claimant resulted in a balance in their favor, which entails an obligation for the entity being claimed against to reimburse amounts. According to the claimant, the clinic must reimburse them for an amount overpaid for a treatment received.

To carry out these reimbursements, the entity being claimed against has required its clients, prior to the reimbursement, to provide a photocopy of their identity document. The reimbursement of the amount in question is conditioned by the Clinic on the delivery of a photocopy of this document, as stated by the Clinic, to verify the identity of the client and ensure that the reimbursement is made to the correct person.

This has occurred in the present case, in which the Clinic has rejected, according to the claimant, all the alternatives proposed to effectuate the reimbursement, among which they mention reimbursement via transfer to the bank account that has already been communicated to the entity being claimed against, a nominative or cash check, with the corresponding receipt signed.

This Agency understands that the contractual relationship that entails the provision of dental services to a client (the claimant) justifies the access by the entity being claimed against to the personal data of the individuals receiving them, as long as it is necessary for the fulfillment of the obligations arising from such service provision; but it does not justify access to all the information contained in the client's identity document and, even less, the collection and retention of a photocopy of this document without a legal basis justifying it.

Given that the purpose is to return an amount to a person due to the cancellation of a treatment or another reason, it means that this is an already identified client of the Clinic who has made previous payments, so that reimbursement can be made using the information already available and without the need to collect the additional information referred to in the claim.

If, as the claimant states, the entity being claimed against already had their bank account and accepted the return of the amount via transfer to that account, there are no grounds for requiring a copy of the client's identity document. The same can be said regarding the other means proposed by the claimant for the amount in question to be satisfied, such as payment via nominative check or cash payment simply by verifying their identity and signing the corresponding receipt for the delivery of cash.

Thus, the collection of the photocopy of the client's identity document, generally required by the entity being claimed against, with all the information contained in that document, is understood as a processing of personal data that is inadequate, irrelevant, and unnecessary for the specific purpose of processing, contrary to the principles of data protection, specifically, the principle of "data minimization," regulated in Article 5.1.c) of the GDPR.

Consequently, in accordance with the evidence presented, the aforementioned facts constitute a violation by the entity being claimed against of the provisions of Article 5.1.c) of the GDPR, which gives rise to the application of the corrective powers that Article 58 of the aforementioned Regulation grants to the Spanish Agency for Data Protection.

III

Unfulfilled obligation. Claim before the Data Protection Officer

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/17

The LOPDGDD, in its Exposition of Motives, highlights an important aspect regarding the figure of the data protection officer by stating that "it allows for the establishment of a means for the amicable resolution of complaints, as the interested party may present before him the complaint that has not been addressed by the data controller or processor."

This aspect is related to the right that Article 38.4 of the GDPR recognizes for interested parties to "contact the data protection officer regarding all matters related to the processing of their personal data and the exercise of their rights under this Regulation," which is also included in Article 37.1 of the LOPDGDD, which establishes the following:

"Article 37. Intervention of the data protection officer in the event of a complaint before the data protection authorities.

1. When the data controller or processor has designated a data protection officer, the affected party may, prior to submitting a complaint against them to the Spanish Agency for Data Protection or, where applicable, to the regional data protection authorities, address the data protection officer of the entity against which the complaint is made.

In this case, the data protection officer shall communicate to the affected party the decision that has been adopted within a maximum period of two months from the receipt of the complaint."

In the present case, it is evidenced that the complaining party, on 24/12/2022, sent an email to the Clínica Dental Sagrada Familia, in Barcelona, addressed <>, highlighting the determining facts of the infringement mentioned in the previous Legal Basis, regarding the requirement of a photocopy of the ID of the complaining party to effect the reimbursement of an amount in their favor. By means of this email, the complaining party attached the report prepared by this Agency in response to an inquiry of theirs regarding the same facts and requests the intervention of the data protection officer in the sense expressed in said report.

It is also evidenced that the complaint raised by the complaining party before the data protection officer was not communicated to him by the organization of the complained party, thereby preventing a solution to the raised issues, which remained unanswered. Only when the complaining party filed the complaint before this Agency did the data protection officer respond to the other complaint of 24/12/2024, during the transfer procedure of the complaint mentioned in Background Second.

The data protection officer of the complained party, in his response to said transfer procedure of the complaint, confirmed the factual circumstances indicated.

This conduct of the complained party constitutes a breach of Article 38 of the GDPR, which establishes the following:

“Article 38. Position of the data protection officer

1. The data controller and the processor shall ensure that the data protection officer is involved adequately and in a timely manner in all issues related to the protection of personal data.
2. The data controller and the processor shall support the data protection officer...”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/17

data in the performance of the functions mentioned in Article 39, providing the necessary resources for the performance of such functions and access to personal data and processing operations, and for the maintenance of their specialized knowledge.

3. The controller and the processor shall ensure that the data protection officer receives no instructions regarding the performance of such functions. They shall not be dismissed or sanctioned by the controller or the processor for performing their functions. The data protection officer shall report directly to the highest hierarchical level of the controller or processor.

4. Data subjects may contact the data protection officer regarding all matters related to the processing of their personal data and the exercise of their rights under this Regulation.

5. The data protection officer shall be obliged to maintain secrecy or confidentiality regarding the performance of their functions, in accordance with Union law or the laws of the Member States.

6. The data protection officer may perform other functions and tasks. The controller or processor shall ensure that such functions and tasks do not lead to a conflict of interest.

The respondent has indicated that the complaint directed by the complainant to the DPO of the entity was not forwarded to them due to an oversight, without intent, by the person who received the communication, and the cause of this omission could not be determined.

However, this Agency understands that failing to forward the complaint to the DPO amounts to not processing it, to not handling it due to a malfunction of the internal channels established by the entity, which cannot be accepted as an unintentional error.

The incident occurs within the scope of responsibility of the respondent, and this entity must be held accountable for it. It cannot be considered that the alleged error excludes their responsibility, since, according to established case law, the existence of such an error cannot be deemed to exist when it is attributable to the one suffering it or could have been avoided with greater diligence. In this case, the alleged error is incompatible with the diligence that the respondent is obliged to observe, which must be manifested in the specific case being analyzed, regarding which the error is alleged.

In the specific case of the complainant, it cannot be accepted that the action of the respondent, not processing the complaint directed to the DPO, was diligent. To admit that it is not appropriate to demand responsibility for this fact, based on a supposed unintentional error consisting of not processing the complaint, would be tantamount to admitting that the application of the GDPR and the LOPDGDD can be ignored, undermining the entire system established in relation to the figure of the data protection officer, in which the obligation to respond to such complaints is expressly contemplated in any case, within a period of two months.

In this regard, it should be noted that when the error is indicative of a lack of diligence, the type is applicable. The National Court in its Judgment of September 21, 2004 (RCA 937/2003), states the following:

"Furthermore, regarding the application of the principle of culpability, it results (following the criteria of this Chamber in other Judgments such as that of January 21, 2004, issued in appeal 1139/2001) that the commission of the infringement provided for in Article 44.3.d) can be both...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/17

intentional or negligent. In this regard, if the error demonstrates a lack of diligence, the type is applicable, since although the principle of culpability governs in sanctioning matters, as inferred from a simple reading of Article 130 of Law 30/1992, it is true that the expression "simple noncompliance" in Article 130.1 of Law 30/1992 allows for the imposition of a sanction, undoubtedly in cases of intent, and also in cases of negligence, as mere noncompliance with the duty of care suffices.

In this line, it is pertinent to cite the SAN of January 21, 2010, in which the Court states:

"The appellant also maintains that there is no culpability in her actions. It is true that the principle of culpability prevents the admission of objective liability in administrative sanctioning law; it is also true that the absence of intent is secondary since these types of infractions are typically committed through negligent or careless actions, which is sufficient to integrate the subjective element of fault. The actions of XXX are clearly negligent as... she must know... the obligations imposed by the LOPD on all those who handle personal data of third parties. XXX is obliged to guarantee the fundamental right to the protection of personal data of her clients and potential clients with the intensity required by the content of the right itself."

The principle of culpability is required in the sanctioning procedure, and thus the STC 246/1991 considers it inadmissible in the realm of administrative sanctioning law to have liability without fault. However, the principle of fault does not imply that only intentional or voluntary actions can be sanctioned, and in this regard, Article 28 of Law 40/2015 on the Legal Regime of the Public Sector, under the heading "Liability," states the following:

"1. Only individuals and legal entities, as well as, when a law recognizes them the capacity to act, groups of affected parties, unions, and entities without legal personality and independent or autonomous assets, that are responsible for the same by way of intent or negligence, may be sanctioned for acts constituting administrative infractions."

The facts presented demonstrate that the party being claimed did not act with the diligence to which it was obligated and acted with a lack of diligence. The Supreme Court (Judgments of April 16 and 22, 1991) considers that from the culpability element it follows that "the action or omission, classified as an administratively sanctionable infraction, must, in any case, be attributable to its author, by intent or imprudence, negligence, or inexcusable ignorance." The same Court reasons that "it is not enough... for exculpation against a typically unlawful behavior to invoke the absence of fault," but it is necessary "that the diligence required by the one claiming its nonexistence has been employed" (STS January 23, 1998).

Also connected with the degree of diligence that the data controller is obliged to exercise in fulfilling the obligations imposed by data protection regulations is the SAN of October 17, 2007 (Rec. 63/2006), which specified: "(...) the Supreme Court has understood that there is imprudence whenever a legal duty of care is neglected, that is, when the infringer does not behave with the required diligence."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
10/17

Furthermore, the National Court, in matters of personal data protection, has declared that "simple negligence or failure to comply with the duties imposed by the Law on those responsible for files or data processing to exercise due diligence is sufficient..." (SAN 29/06/2001).

Consequently, in accordance with the evidence presented, the aforementioned facts constitute a violation by the responding party of the provisions of Article 38 of the GDPR, which gives rise to the application of the corrective powers granted to the Spanish Agency for Data Protection by Article 58 of the aforementioned Regulation.

IV

Classification and Qualification of the Violations

In accordance with the above, it is considered that the responding party processes personal data of its clients that is excessive, as it is not necessary for the purpose for which it is collected. Furthermore,

there is evidence of a possible obstruction of the effective action of the data protection officer. The known facts constitute a violation, attributable to the responding party, of Article 5.1.c) of the GDPR, with the scope expressed in the previous Legal Foundations, which implies the commission of the violation classified in Article 83.5, paragraph a), of the GDPR, which under the heading "General conditions for the imposition of administrative fines" states the following:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9." In this regard, the LOPDGDD, in its Article 71, establishes that "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute violations."

For the purposes of the statute of limitations, Article 72 of the LOPDGDD states:

Article 72. Very serious violations.

"1. Based on what is established in Article 83.5 of Regulation (EU) 2016/679, the following violations are considered very serious and shall be subject to a three-year statute of limitations: violations that constitute a substantial infringement of the articles mentioned therein and, in particular, the following:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679."

On the other hand, the violation of the provisions of Article 38 of the GDPR is classified in Article 83.4.a) of the aforementioned GDPR in the following terms:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/17

"4. Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43. (...)"

And Article 73 of the LOPDGDD, for the purposes of the statute of limitations, qualifies as "Serious Violations":

"Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following violations are considered serious and shall be subject to a two-year statute of limitations: violations that constitute a substantial infringement of the articles mentioned therein and, in particular, the following:

(...)

w) Not enabling the effective participation of the data protection officer in all matters relating to the protection of personal data, not supporting him or interfering with the performance of his duties.

(...)"

V

Corrective Powers

In the event of a violation of the provisions of the GDPR, among the corrective powers available to the Spanish Agency for Data Protection, as the supervisory authority, Article 58.2 of that Regulation includes the following:

"2 Each supervisory authority shall have all of the following corrective powers:

(...)

b) issue a warning to any controller or processor when the processing operations have infringed the provisions of this Regulation;

(...)

d) order the controller or processor to bring the processing operations into compliance with the provisions of this Regulation, when appropriate, in a specific manner and within a specified time frame; (...)

i) impose an administrative fine in accordance with Article 83, in addition to or instead of the measures mentioned in this paragraph, depending on the circumstances of each particular case.”

According to the provisions of Article 83.2 of the GDPR, the measure provided for in the previous letter d) is compatible with the sanction consisting of an administrative fine.

VI

Proposal for Sanction

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR must be observed, which state:

“1. Each supervisory authority shall ensure that the imposition of administrative fines is...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/17

In accordance with this article, for the infringements of this Regulation indicated in sections 4, 9, and 6, the penalties shall be effective, proportionate, and dissuasive in each individual case.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those contemplated in Article 58, section 2, letters a) to h) and j). In deciding the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

- a) the nature, severity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of affected individuals and the level of damages suffered;
- b) the intentionality or negligence in the infringement;
- c) any measures taken by the data controller or processor to mitigate the damages suffered by the affected individuals;
- d) the degree of responsibility of the data controller or processor, considering the technical or organizational measures they have applied under Articles 25 and 32;
- e) any previous infringement committed by the data controller or processor;
- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, in particular whether the data controller or processor notified the infringement and, if so, to what extent;
- i) when the measures indicated in Article 58, section 2, have been previously ordered against the data controller or processor in relation to the same matter, the compliance with such measures;
- j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42, and
- k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as financial benefits obtained or losses avoided, directly or indirectly, through the infringement.”

Regarding section k) of Article 83.2 of the GDPR, the LOPDGDD, Article 76, “Sanctions and corrective measures,” provides:

“1. The sanctions provided for in sections 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the criteria for graduation established in section 2 of the aforementioned article.

2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The continued nature of the infringement.
- b) The link between the infringer's activity and the processing of personal data.

- c) The benefits obtained as a result of the commission of the infringement.
- d) The possibility that the conduct of the affected individual could have induced the commission of the infringement.
- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) Having, when not mandatory, a data protection officer.
- h) The voluntary submission by the data controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any affected individual."

In this case, considering the severity of the alleged infringements observed,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/17

that arise from the improper collection of copies of the identity documents of the clients of the defendant party and from the failure to process a complaint directed by the claimant party to the DPD of the defendant party, the imposition of a fine is warranted, in addition to the adoption of measures, if applicable.

The fine imposed must be, in each individual case, effective, proportionate, and deterrent, in accordance with the provisions of Article 83.1 of the GDPR. Thus, the condition of the defendant party as a medium-sized enterprise is considered (...).

In accordance with the aforementioned provisions, for the purpose of determining the amount of the sanctions to be imposed in this case, it is deemed appropriate to gradate the sanctions according to the following criteria established by the transcribed provisions:

1. Violation of Article 5.1.c) of the GDPR, classified in Article 83.5.a) of the aforementioned Regulation, and qualified as very serious for the purposes of prescription in Article 72.1.a) of the LOPDGDD:

The following aggravating criteria are considered concurrent:

. Article 83.2.a) of the GDPR: "a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of affected parties and the level of damage and harm they have suffered."

The Agency considers that the nature of the infringement is very serious, as it affects identity documentation of individuals; it affects all clients of the defendant party who are in the same situation as the claimant party; and it causes harm to the interested parties who have the right to reimbursement of amounts, which is not satisfied immediately due to the requirement imposed by the defendant party.

. Article 83.2.b) of the GDPR: "b) the intentionality or negligence in the infringement."

Intentionality or negligence in the infringement: although the Agency considers that there was no intentionality on the part of the defendant party, it concludes that its actions are negligent, as it established excessive requirements for the reimbursement of amounts.

. Article 83.2.g) of the GDPR: "g) the categories of personal data affected by the infringement."

Categories of personal data affected by the infringement: although "Special categories of personal data," as defined by the GDPR in Article 9, have not been affected, the personal data referred to in the proceedings (image of the identity documentation of clients) has a particularly sensitive nature and increases the risks to their privacy.

. Article 76.2.b) of the LOPDGDD: "b) The link between the infringer's activity and the processing of personal data."

The high link of the infringer's activity with the processing of personal data, considering the activity it develops. This circumstance determines a higher degree of demand and professionalism and, consequently, of responsibility of the defendant entity in relation to the processing of the data.

Considering the factors presented, the assessment of the fine for the infringement of Article 5.1.c) of the GDPR is 20,000 euros (twenty thousand euros).

2. Violation of Article 38 of the GDPR, classified in Article 83.4.a) of the aforementioned GDPR, and qualified as serious for the purposes of prescription in Article 73.w) of the GDPR:

The following aggravating criteria are considered concurrent:

. Article 83.2.b) of the GDPR: “b) the intentionality or negligence in the infringement.”

Intentionality or negligence in the infringement: it is concluded that the actions of the defendant party are negligent, as it did not process a complaint expressly directed by the claimant party to the DPD of the responsible entity.

. Article 76.2.b) of the LOPDGDD: “b) The link between the infringer's activity and the processing of personal data.”

The high link of the infringer's activity with the processing of personal data, already justified in relation to the previous infringement.

It is also considered that the following mitigating circumstance applies:

. Article 83.2.a) of the GDPR: “a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of affected parties and the level of damage and harm they have suffered.”

The infringement only affects the claimant party.

Considering the factors presented, the assessment of the fine for the infringement of Article 38 of the GDPR is 10,000 euros (ten thousand euros).

VII

Adoption of measures

Once the infringements have been confirmed, it is appropriate to impose on the reported party the obligation to adopt adequate measures to adjust its actions to the regulations mentioned in this act, in accordance with the provisions of Article 58.2 d) of the GDPR, according to which each supervisory authority may “order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specified manner and within a specified time frame...”. The imposition of this measure is compatible with the sanction consisting of an administrative fine, as provided in Article 83.2 of the GDPR.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/17

The text of this resolution establishes what the infringements committed have been and the facts that give rise to the violation of data protection regulations, from which it is clearly inferred what measures are to be adopted, without prejudice to the fact that the type of procedures, mechanisms, or specific instruments for implementing them corresponds to the sanctioned party, as it is the data controller who fully understands its organization and must decide, based on proactive responsibility and a risk-based approach, how to comply with the GDPR and the LOPDGDD.

However, in this case, regardless of the above, it is appropriate to require the responding party to cease the processing in question within the timeframe determined in the dispositive part, refraining from continuing to request a copy of the identity document of its clients as a requirement for carrying out refunds.

On the other hand, regarding the obligation to address the claims made by the interested parties to the data protection officer, it is noted in the proceedings that the responding party has issued instructions to all its staff regarding the necessity of forwarding all communications directed to the DPO, regardless of the channel chosen by the interested person, and that the DPO will carry out recurring and random simulations in all clinics to verify compliance with the established protocol. Therefore, regarding this infringement, the imposition of additional measures beyond those already adopted is not warranted. Finally, it is warned that failure to comply with the requirements of this body may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its articles 83.5 and 83.6, which may lead to the initiation of further administrative sanctioning procedures.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of sanctions whose existence has been established, the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on APOLLONIA TOPCO, S.L., with NIF B88526116, the following fines:

. For an infringement of article 5.1.c) of the GDPR, classified in article 83.5.a) of the same Regulation, and qualified as very serious for the purposes of prescription in article 72.1.a) of the LOPDGDD, a fine of 20,000 euros (twenty thousand euros).

. For an infringement of article 38 of the GDPR, classified in article 83.4.a) of the same Regulation, and qualified as serious for the purposes of prescription in article 73.w) of the LOPDGDD, a fine of 10,000 euros (ten thousand euros).

SECOND: NOTIFY this resolution to APOLLONIA TOPCO, S.L.

THIRD: ORDER APOLLONIA TOPCO, S.L., that pursuant to article 58.2.d) of the GDPR, within one month from the notification of this act, it shall adjust its actions to the personal data protection regulations, to the extent

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/17

expressed in the Legal Basis VII. Within the same period indicated, APOLLONIA TOPCO, S.L. must justify before this Spanish Agency for Data Protection the compliance with this requirement.

FOURTH: To warn the sanctioned party that they must fulfill the imposed sanction once this resolution becomes executive, in accordance with the provisions of art. 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), within the voluntary payment period established in art. 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to art. 62 of Law 58/2003, of December 17, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, into the restricted account no.

IBAN: ES00-0000-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX), opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A. Otherwise, collection will proceed in the executive period.

Upon receiving the notification and once it is executive, if the date of executivity falls between the 1st and the 15th of each month, inclusive, the deadline for making the voluntary payment will be until the 20th of the following month or the next business day, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day.

In accordance with the provisions of article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with art. 48.6 of the LOPDGDD, and in accordance with the provisions of article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file an administrative contentious appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of article 25 and section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in article 46.1 of the aforementioned Law.

Finally, it is noted that in accordance with the provisions of art. 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file an administrative contentious appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency

[<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in art. 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the administrative contentious appeal. If the Agency is not aware of the filing of the administrative contentious appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

17/17

938-010623

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es